PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Cybersécurité TPE et PME

08-42 DGE et ANSSI - La cybersécurité pour les TPE et PME en 13 questions — source : fiche de révision du module (gemma4, 03/11/2026)

À RETENIR

1. L'inventaire des équipements, logiciels, données et accès doit être mis à jour au moins une fois par an.
2. La stratégie de sauvegarde doit inclure des copies sur des supports déconnectés et être testée par restauration.
3. En cas d'incident, il faut déconnecter l'équipement d'Internet sans l'éteindre ni le modifier.

Protection du patrimoine numérique

Notion	À retenir
Inventaire des actifs	Inventorier équipements, logiciels (versions/licences), données, accès et interconnexions. Mise à jour **au moins une fois par an**.
Stratégie de sauvegarde	Compléter les sauvegardes en ligne/cloud (exposées aux rançongiciels) par des **sauvegardes hors ligne** (règle **3-2-1**). Tester par restauration et chiffrer.
Mises à jour et antivirus	Appliquer les correctifs **dès que possible** (mise à jour automatique). Antivirus : base de signatures mise à jour fréquemment.

Authentification, filtrage et messagerie

Notion	À retenir
Mots de passe	**9** caractères min. (peu critique), **15** (critique) ; majuscules, minuscules, chiffres, spéciaux ; **un mot de passe par service** ; **coffre-fort certifié ANSSI**, **MFA**, jetons, **single sign on**. Attaques : force brute, dictionnaire, ingénierie sociale.
Pare-feu	TPE : **pare-feu préinstallé**. PME : pare-feux **physiques**, flux non nécessaires bloqués et journalisés, **DMZ**, **segmentation** (freine les déplacements latéraux).
Messagerie	Vecteur d'infection (**pièces jointes, liens**) : vérifier expéditeur, attente, lien ; doute → **autre canal**. Pas de **redirection vers messagerie personnelle**. PME : analyse des pièces jointes en amont, **antispam**, **TLS**, **serveur relais**.

Usages, nomadisme et sensibilisation

Notion	À retenir
Séparation usages	Compte utilisateur **sans privilège d'administration** pour naviguer ; comptes d'administration pour **configurer/installer**. Idéal : ordinateur dédié ou **un compte par usage**.
Nomadisme	Menaces : **espionnage**, **piégeage** (enregistreur de frappe), **vol**. Réflexes : filtre confidentialité, chiffrement disque, verrouillage **< 5 min**, refus des équipements de tiers, chargeur personnel, partage **4G/5G** plutôt que les portails captifs d'hôtel.
Information	TPE : **Cybermalveillance.gouv.fr** (prestataires labellisés **ExpertCyber**). PME : veille **CERT-FR**. Charte informatique (usages/incidents) remise à chaque nouvel arrivant. Déclaration encouragée par réponse **non coercitive** (sauf action délibérée).

Assurance, incident et cloud

Notion	À retenir
Assurance et réaction	**Assurance** : couvrir usurpation, perte d'exploitation, juridique, restauration. **Incident** : déconnecter d'Internet sans éteindre/modifier. **Rançon** : ne jamais payer. **Actions** : main courante, plainte, déclaration **CNIL**.
Le cloud	**Risques** : dépendance liaisons, défaut configuration. **TPE** : 2FA, sauvegardes (en ligne/hors ligne), alertes, **HTTPS**. **PME** : + authentification fédérée, accès postes réservés, **VPN** chiffrés. **SecNumCloud** : protection contre contentieux pays concurrents.

Pièges et confusions

- ⚠ Croire qu'il existe une solution miracle ou un risque zéro.
- ⚠ Penser que le cloud est mieux sécurisé par nature.
- ⚠ Considérer que l'argument de la sécurité du cloud dispense d'une approche méthodique.
- ⚠ Attendre l'incident pour se préparer, car il sera alors trop tard.

Sigles et définitions

SI	ensemble des matériels, logiciels, données et traitements qui constituent le patrimoine informationnel de l'entreprise
Règle 3 2 1	impose trois copies de sauvegarde, sur deux supports différents, dont une hors ligne
Phrase de passe	constituée de mots choisis aléatoirement dans un corpus, plus longue qu'un mot de passe classique
2FA	authentification à deux facteurs, ajoute au mot de passe un second élément
Single sign on	service d'authentification unifié qui renforce l'authentification et simplifie l'expérience de l'utilisateur
DMZ	zone démilitarisée, constituée de pare-feux et de services de rebond pour l'interconnexion avec Internet
VPN en mode full tunneling	fait transiter l'ensemble des flux du poste par le tunnel chiffré, en IPsec ou en TLS
SecNumCloud	visa de sécurité de l'ANSSI pour les services cloud, garantissant la sécurité de l'infrastructure et une protection juridique contre les lois extracommunautaires

Auto-test

1. Quelle est la règle de sauvegarde recommandée ?
2. Combien de caractères minimum faut-il pour un mot de passe de service critique ?
3. Que faut-il faire face à une demande de rançon ?
4. Quel label identifie les prestataires informatiques de proximité compétents en sécurité ?
5. Quel est le délai de verrouillage recommandé pour un ordinateur en situation de nomadisme ?

Réponses : **1.** 3 2 1 · **2.** 15 · **3.** Ne jamais payer · **4.** ExpertCyber · **5.** < 5 min

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.